CYBER SECURITY

> **Ethics:** Everything in this chapter is for **learning and defense**. Scanning, testing or attacking systems without written permission is illegal (in Sri Lanka under the Computer Crimes Act No. 24 of 2007, and in most countries). Practise only in your own lab or on authorized platforms. Attack techniques are explained here mainly so that you understand how to **detect and prevent** them.

Vulnerability Assessment & Threat Landscape

Fundamentals of Vulnerabilities

Term	Meaning
Asset	Anything valuable: data, server, application, people
Vulnerability	A weakness that can be exploited (unpatched software, weak password, misconfiguration)
Threat	Something or someone that can exploit a vulnerability (hacker, malware, natural disaster)
Exploit	Code or technique that uses a vulnerability
Risk	The likelihood of a threat exploiting a vulnerability × the impact (Risk = Threat × Vulnerability × Impact)
Zero-day	A vulnerability unknown to the vendor, with no patch available
CVE	Common Vulnerabilities and Exposures: a unique ID for each public vulnerability (e.g., CVE-2017-0144)
CVSS	Common Vulnerability Scoring System: score from 0 to 10 for severity (Low, Medium, High, Critical)

Types of vulnerabilities

- **Software:** bugs such as buffer overflow, SQL injection, cross-site scripting (XSS).
- **Configuration:** default passwords, open ports, excessive permissions.
- **Patch / update:** missing security updates.
- **Network:** weak protocols (Telnet, FTP), open Wi-Fi, no segmentation.
- **Human:** untrained users, poor password habits.
- **Physical:** unlocked server rooms, stolen devices.

Vulnerability assessment vs penetration testing

Point	Vulnerability Assessment	Penetration Test
Goal	Find and list weaknesses	Actively exploit weaknesses (with permission) to prove the impact
Method	Mostly automated scanning (Nessus, OpenVAS, Qualys)	Manual and automated; creative; simulates a real attacker
Depth	Broad	Deep
Result	A prioritized list of vulnerabilities	A report of how far an attacker could get

Vulnerability management cycle: discover assets → scan → analyze and prioritize (CVSS and business impact) → remediate (patch, configure) → verify → report → repeat.

Social Engineering

Social engineering is manipulating **people** instead of breaking technology. It exploits trust, fear, urgency and helpfulness. It is often the easiest way into an organization, because "the human is the weakest link."

Technique	Description
Phishing	Fake emails that look genuine, to steal credentials or deliver malware
Spear phishing / whaling	Targeted phishing against a specific person, or senior executives
Vishing	Voice calls pretending to be a bank, IT support or a government officer
Smishing	Fake SMS messages with malicious links
Pretexting	Invented story to obtain information ("I am from the IT department...")
Baiting	Leaving an infected USB drive or offering a "free" download
Tailgating / piggybacking	Following an authorized person through a secured door
Impersonation / shoulder surfing / dumpster diving	Pretending to be someone else, watching screens, searching trash for information
Business Email Compromise (BEC)	Fake or hijacked executive email asking for urgent payment

Defenses

- Regular **security awareness training** and phishing simulations.
- Verify unusual requests through a **second channel** (call back on a known number).
- Email filtering, link protection, **MFA** (so a stolen password alone is not enough).
- Clear procedures for payments and password resets; visitor badges and access control.
- Encourage a culture where staff **report** suspicious messages without fear.

Hardware Hacking Tools

Some attacks use small physical devices that are plugged in or placed near the target. Knowing them helps you understand why **physical security and USB control** matter.

Device type	What it is (concept)	Defense
Hardware keylogger	A small device between the keyboard and the computer that records keystrokes	Inspect ports and cables; secure computers physically
Malicious USB / "keystroke injection" devices (e.g., USB Rubber Ducky, O.MG cable)	Look like a normal flash drive or cable but act as a keyboard and type commands very fast	Disable or restrict USB ports, allow-list devices, endpoint device control
Multi-tool devices (e.g., Flipper Zero)	Pocket tool that can interact with RFID, NFC, infrared and radio signals	Use modern encrypted access cards, do not rely on simple RFID cloning-prone cards
Wi-Fi attack/test devices (e.g., Wi-Fi Pineapple)	Used by testers to create rogue access points and study wireless risks	WPA3 / 802.1X, wireless IDS, user awareness about open Wi-Fi
Network implants (small PCs like Raspberry Pi, LAN Turtle)	Hidden device plugged into a network port to give remote access	Port security (802.1X, NAC), disable unused ports, regular physical inspection
RFID / badge cloners	Copy simple access cards	Use secure card technologies and multi-factor entry
SDR (Software Defined Radio)	Radio receiver used to study wireless signals	Encrypted wireless protocols

Threat Actors and Attack Motives

Threat actor	Description	Main motive
Script kiddies	Low-skill people using ready-made tools	Curiosity, fame, fun

Threat actor	Description	Main motive
Hacktivists	Hackers with a political or social cause (e.g., Anonymous)	Ideology, protest
Cyber criminals	Organized groups running ransomware, fraud, data theft	Money
Insiders	Employees or contractors with legitimate access (malicious or careless)	Revenge, money, or accident
Nation-state / APT	Government-backed groups with big resources (**Advanced Persistent Threats**)	Espionage, sabotage, strategic advantage
Competitors / corporate spies	Steal trade secrets	Business advantage
Terrorist groups	Attack critical infrastructure	Fear, disruption
Ethical hackers (white hat)	Authorized testers who help defenders	Improve security

Hat colors: White hat = ethical and authorized. **Black hat** = malicious. **Grey hat** = in between (finds weaknesses without permission but may report them).

Hacking Methodologies

Attackers (and ethical hackers) follow organized steps. Knowing them helps defenders put controls at each stage.

Ethical hacking phases

1. **Reconnaissance (footprinting):** collect information about the target. **Passive** (public information: websites, DNS, social media, WHOIS) and **active** (directly touching the target).
2. **Scanning and enumeration:** discover live hosts, open ports, services and users.
3. **Gaining access (exploitation):** use a vulnerability or stolen credentials.
4. **Maintaining access:** install persistence (backdoors, new accounts, scheduled tasks).
5. **Covering tracks:** delete or alter logs. (Defenders use central logging and immutable logs to defeat this.)
6. **Reporting:** in ethical hacking, document findings and recommendations.

Lockheed Martin Cyber Kill Chain

Reconnaissance → Weaponization → Delivery → Exploitation → Installation → Command & Control (C2) → Actions on Objectives. The defender's goal is to **break the chain** at any step.

MITRE ATT&CK

A public knowledge base of real attacker **tactics** (the goal, e.g., Initial Access, Persistence, Privilege Escalation, Lateral Movement, Exfiltration) and **techniques** (how). It is widely used for threat detection, red/blue team exercises and EDR rules.

Other methodologies

- **PTES** (Penetration Testing Execution Standard), **OWASP Testing Guide** (web applications), **NIST SP 800-115**, **OSSTMM**.
- **Red team** = simulated attackers, **Blue team** = defenders, **Purple team** = both working together.

Network Scanning

Network scanning discovers which devices are alive in a network, which **ports** are open and what **services and versions** are running. Defenders do it to find weaknesses before attackers do. The most famous tool is **Nmap** ("Network Mapper"). Others: Angry IP Scanner, Masscan, Nessus, OpenVAS.

What scanning finds

- **Host discovery:** which IP addresses respond (ping sweep, ARP scan).
- **Port scanning:** which TCP / UDP ports are open, closed or filtered.
- **Service and version detection:** what software (and version) listens on each port.
- **OS fingerprinting:** guess the operating system.
- **Vulnerability scanning:** match versions to known vulnerabilities.

Common scan types

Scan	How it works
TCP connect scan	Completes the full 3-way handshake with the port; reliable but easy to log
SYN scan ("half-open / stealth")	Sends SYN, receives SYN-ACK (open) or RST (closed), never completes the handshake; faster and less logged
UDP scan	Sends UDP packets; slower because there is no handshake
ACK scan	Used to map firewall rules
Ping sweep	Finds live hosts in a subnet

Basic Nmap examples (run only on your own lab or authorized networks)

```
nmap 192.168.1.10            # scan the most common 1000 ports of one host
nmap -sn 192.168.1.0/24      # host discovery only (ping scan), no port scan
nmap -sV 192.168.1.10        # detect service versions
```

```
nmap -O 192.168.1.10          # OS detection
nmap -p 22,80,443 192.168.1.10 # scan specific ports
nmap -A 192.168.1.10          # aggressive: OS, version, scripts, traceroute
```

Defending against scanning

- Firewall rules that expose only required ports; close unused services.
- Intrusion detection / prevention (IDS/IPS) and logging to detect scan patterns.
- Network segmentation and rate limiting.
- Run **your own** regular internal and external scans to find exposures first.

Active Directory (AD) Exploitation & Network Attacks

Because Active Directory controls identity for almost every Windows network, it is the **number one target** for attackers. Once an attacker gets domain admin rights, they control everything.

Active Directory Architecture & Vulnerabilities

Quick architecture reminder

- **Domain Controllers (DC)** store the AD database (NTDS.dit) and authenticate users.
- **Kerberos** is the main authentication protocol; **NTLM** is the older fallback protocol.
- **DNS, LDAP, SMB** support AD functions. **Group Policy** pushes settings to computers.
- Logical structure: forest → domains → OUs → users, groups, computers.

Common AD weaknesses (why attacks work)

Weakness	Why it is dangerous	Fix
Weak or reused passwords, no MFA	Easy to guess or steal	Strong passphrases, MFA, banned password lists
Legacy protocols (NTLM, SMBv1, LLMNR, NBT-NS)	Allow credential capture and relay	Disable or restrict; use Kerberos
SMB signing not required	Allows relay attacks	Require SMB signing
Over-privileged accounts (too many Domain Admins)	One stolen account = total control	Least privilege, tiered admin model, separate admin accounts
Service accounts with weak passwords and SPNs	Their Kerberos tickets can be requested and cracked offline ("Kerberoasting")	Long random passwords, gMSA
Passwords stored in GPP or scripts	Easily read by any user	Remove them; use LAPS
Unpatched DCs and servers	Known exploits (e.g., Zerologon, EternalBlue)	Patch quickly

Weakness	Why it is dangerous	Fix
Poorly secured certificate services (AD CS) and delegation settings	Allow privilege escalation	Review templates and permissions
No monitoring of AD	Attacks go unnoticed	Audit logs, SIEM, Microsoft Defender for Identity

Typical attack path in a Windows domain (concept)

Initial access (phishing or exposed service) → capture or steal a low-privileged credential → discover the domain and its users → escalate privileges (misconfigurations, weak service accounts) → **lateral movement** to other machines → reach a Domain Controller → persistence and data theft. The defender's goal is to stop or detect each step.

LLMNR Poisoning & SMB Relay Attacks

LLMNR / NBT-NS poisoning (concept)

When a Windows computer cannot resolve a name using DNS (for example when a user mistypes a server name such as \\fileservr), it falls back to broadcasting the question to the local network using **LLMNR** (Link-Local Multicast Name Resolution) and **NBT-NS** (NetBIOS Name Service). These protocols have **no authentication**: any device can answer "I am that server!". A malicious device on the same network can answer falsely, and the victim then sends its **username and password hash (NTLMv2)** to the attacker's machine.

> **Example:** You shout in an office, "Where is Mr. Fileserver?" Anyone can shout back "I am here!" and you believe them without checking their ID. Then you hand over your login details.

SMB relay (concept)

Instead of cracking the captured hash, an attacker can **relay** the authentication to another machine in real time. If that machine does not require **SMB signing**, the attacker is logged in as the victim, with the victim's rights. If the victim is an administrator, the attacker may get control of the server.

How to defend (very important)

1. **Disable LLMNR** (Group Policy: Computer Configuration → Administrative Templates → Network → DNS Client → "Turn off multicast name resolution").
2. **Disable NBT-NS** (network adapter → IPv4 advanced → WINS → "Disable NetBIOS over TCP/IP", or via DHCP option).
3. **Require SMB signing** on all servers and clients (Group Policy: "Microsoft network server / client: Digitally sign communications (always)").
4. **Restrict or disable NTLM** and move to Kerberos; enable **Extended Protection for Authentication**.
5. **Network segmentation, NAC / 802.1X** so rogue devices cannot join the network.
6. Use **strong, long passwords** (hash cracking becomes impractical) and **MFA**.

7. Do not give users local admin rights; use tiered administration.
8. **Monitor** for unusual name-resolution responses and unexpected authentications (IDS, SIEM, Defender for Identity).

Exploitation Frameworks & Toolkits

An **exploitation framework** is a software platform that bundles many exploits, payloads and helper tools so testers can check whether vulnerabilities are really exploitable. Examples: **Metasploit Framework**, Cobalt Strike (commercial), Core Impact (commercial), Empire / Sliver / Havoc (command & control frameworks). Penetration testers use them under permission, but criminals also abuse them, so defenders study them to write detections.

Metasploit Framework (MSF)

Metasploit is the most popular open-source penetration testing framework (developed by Rapid7, included in Kali Linux). It is written in Ruby and used through the console `msfconsole`.

Core concepts and module types

Term	Meaning
Exploit	Module that takes advantage of a specific vulnerability
Payload	The code that runs on the target after a successful exploit (for example a shell or Meterpreter session)
Auxiliary	Helper modules: scanners, fuzzers, brute-force checkers, no payload
Post	Post-exploitation modules for gathering information after access
Encoder / NOP	Help shape payloads to avoid bad characters or basic detection
Meterpreter	An advanced, in-memory payload that gives a flexible remote session
RHOSTS / RPORT / LHOST / LPORT	Remote target address / port; local (attacker) address / port

Typical workflow in a lab (concept)

1. Scan and identify the target service and version (for example with Nmap).
2. Search Metasploit for a matching module.
3. Select the module and set the required options (target IP, port, payload).
4. Run the module and check the result.
5. Document the finding and fix the vulnerability (patch / configure).

> **Remember:** For defenders, the value of knowing this is the **detection and patching side**: if a Metasploit module exists for a vulnerability, treat it as "easy to exploit" and patch urgently.

Metasploit Commands

General navigation commands inside `msfconsole` (use only in an authorized lab, such as Metasploitable or a practice VM):

Command	Purpose
`msfconsole`	Start the Metasploit console
`help` / `help <command>`	Show help
`search <keyword>`	Search modules (e.g., by name, CVE, platform, type)
`use <module>`	Select a module (by name or by number from the search results)
`info`	Show details of the selected module
`show options`	Show the settings the module needs
`show payloads` / `show targets`	List compatible payloads / targets
`set <OPTION> <value>`	Set an option (e.g., `set RHOSTS 192.168.56.101`)
`setg <OPTION> <value>`	Set an option globally for all modules
`unset <OPTION>`	Clear an option
`check`	Test if the target looks vulnerable (when the module supports it)
`run` / `exploit`	Execute the module
`back`	Leave the current module
`sessions -l`	List active sessions
`sessions -i <id>`	Interact with a session
`db_status` / `workspace`	Database and project (workspace) management
`db_nmap <options>`	Run Nmap and store the results in the Metasploit database
`hosts` / `services` / `vulns`	Show stored information about discovered hosts, services and vulnerabilities
`exit`	Quit

Auxiliary scanner example (safe discovery in your own lab)

```
msf6 > search type:auxiliary portscan

msf6 > use auxiliary/scanner/portscan/tcp

msf6 auxiliary(scanner/portscan/tcp) > show options

msf6 auxiliary(scanner/portscan/tcp) > set RHOSTS 192.168.56.101

msf6 auxiliary(scanner/portscan/tcp) > run
```

Meterpreter (concept)

After a successful exploit, a Meterpreter session lets the tester run commands such as listing system information, browsing files and gathering evidence for the report. Modern EDR and antivirus products detect Meterpreter behavior, which is a good example of why endpoint protection (previous chapter) is important.

Password Cracking & Scripting Tools

How passwords are stored

Systems should not store passwords directly. They store a **hash**, a one-way mathematical fingerprint of the password. When you log in, the system hashes what you type and compares it with the stored hash. Weak, unsalted and fast hashes (like MD5 or NTLM) are easy to attack, while **salted** and **slow** algorithms (bcrypt, scrypt, Argon2, PBKDF2) are much harder.

Common password attack types (concept)

Attack	Description	Defense
Dictionary attack	Tries words from a list of common passwords	Do not use common words / passwords
Brute force	Tries every possible combination	Long passwords; account lockout; rate limiting
Hybrid / mask attack	Dictionary words with common patterns (Summer2024!) or a known pattern	Avoid predictable patterns
Rainbow table	Pre-computed tables of hashes to reverse them quickly	Salting defeats rainbow tables
Credential stuffing	Uses leaked username/password pairs from other sites	Unique passwords per site; MFA; breach monitoring
Password spraying	Tries one or a few common passwords against many accounts to avoid lockout	MFA; monitoring many failed logins across accounts

Attack	Description	Defense
Pass-the-hash	Uses a stolen hash directly to authenticate without knowing the password	Credential Guard, restrict admin logons, disable NTLM
Offline vs online attacks	Offline: attacker holds the hash and guesses unlimited times. Online: guesses through a login service	Strong hashing, protect hash files, lockout for online

Well-known tools (what each is for)

Tool	Purpose
Hashcat	Very fast offline hash cracking using GPUs
John the Ripper	Popular offline password cracker supporting many formats
Hydra / Medusa	Online login testing against services (SSH, FTP, RDP, web forms)
CrackMapExec / NetExec	Assess credential use and permissions across many Windows hosts
Mimikatz	Research tool that shows how credentials can be extracted from Windows memory (basis for many defenses like Credential Guard)
Wordlists (e.g., rockyou.txt)	Lists of leaked / common passwords used for testing

How to create strong, safe passwords

- Use **passphrases** of 14+ characters, not short complex words.
- Never reuse passwords; use a **password manager**.
- Enable **MFA** everywhere possible.
- Systems should use salted slow hashes, lockout / throttling, and check against breached password lists.
- Audit your own domain's passwords with authorized tools to find weak ones.

Scripting tools in security

Scripting automates repetitive tasks for both defenders and attackers. A system administrator or security engineer should know at least one scripting language.

Language	Typical use in security / administration
PowerShell	Windows administration, AD queries, automation, security auditing; also abused by attackers (fileless attacks), so enable logging and Constrained Language Mode
Bash / shell scripts	Linux administration, log analysis, automation, running tools
Python	Network tools, scanners, parsing logs, automation, API calls, writing security tools
Batch (.bat) and VBScript	Legacy Windows automation
Ruby	Metasploit modules are written in Ruby

> **Example:** A defender's PowerShell script to list AD users whose password never expires: `Get-ADUser -Filter {PasswordNeverExpires -eq $true} | Select Name`. This helps find risky accounts.